

EU AI Act Safety_Governance_Review — Odin_Craft (Second Review)

Project: Odin_Craft	Date: 2026-08-01
Auditor: Stephane Dube — Independent Review	Commit audited: odin_craft@35c2649
Methodology: Static code review + config review + log review (403 cycles) + security tooling verification.	Scope: Technical safety & autonomy risk review for AI agents
Verdict: Documentation now materially complete for voluntary alignment. Still NOT "EU AI Act compliant" in the formal legal sense — internal self-assessment.	

 **Limitations:** This assessment is based on code and logs provided, plus the documentation suite created to close gaps. No live deployment, production data, or third-party dependencies were penetration-tested. The EU AI Act documentation set (docs/eu_ai_act/) is **voluntary, self-assessed due-diligence material** — not a legal conformity opinion.

Executive Summary (Plain English)

What was reviewed & overall verdict. This report reviews Odin_Craft, an AI agent that helps with software development and learning on a single computer. It cannot change its own code or take risky actions without a human saying "yes." Overall assessment: **Low risk** for internal R&D use under human supervision, with strong safety controls (9/10) and a now-complete governance file set (8/10, up from 2/10). It is **not** a formal EU AI Act compliance certificate.

Main strengths:

- **Safety is layered like a vault of locked doors** — every change passes through a safety gate, guardrails, a debate step, an isolated sandbox, and a verification step that can undo anything that breaks.
- **The 8 missing governance documents are now written** — risk classification, risk management, human-oversight SOP, data governance, technical file, transparency notice, threat model, and post-market plan live under docs/eu_ai_act/ .
- **Security tooling is real and verified** — automated secrets scanner, dependency scanner, sandbox escape test (17/17 blocked), and tamper-evident event log.

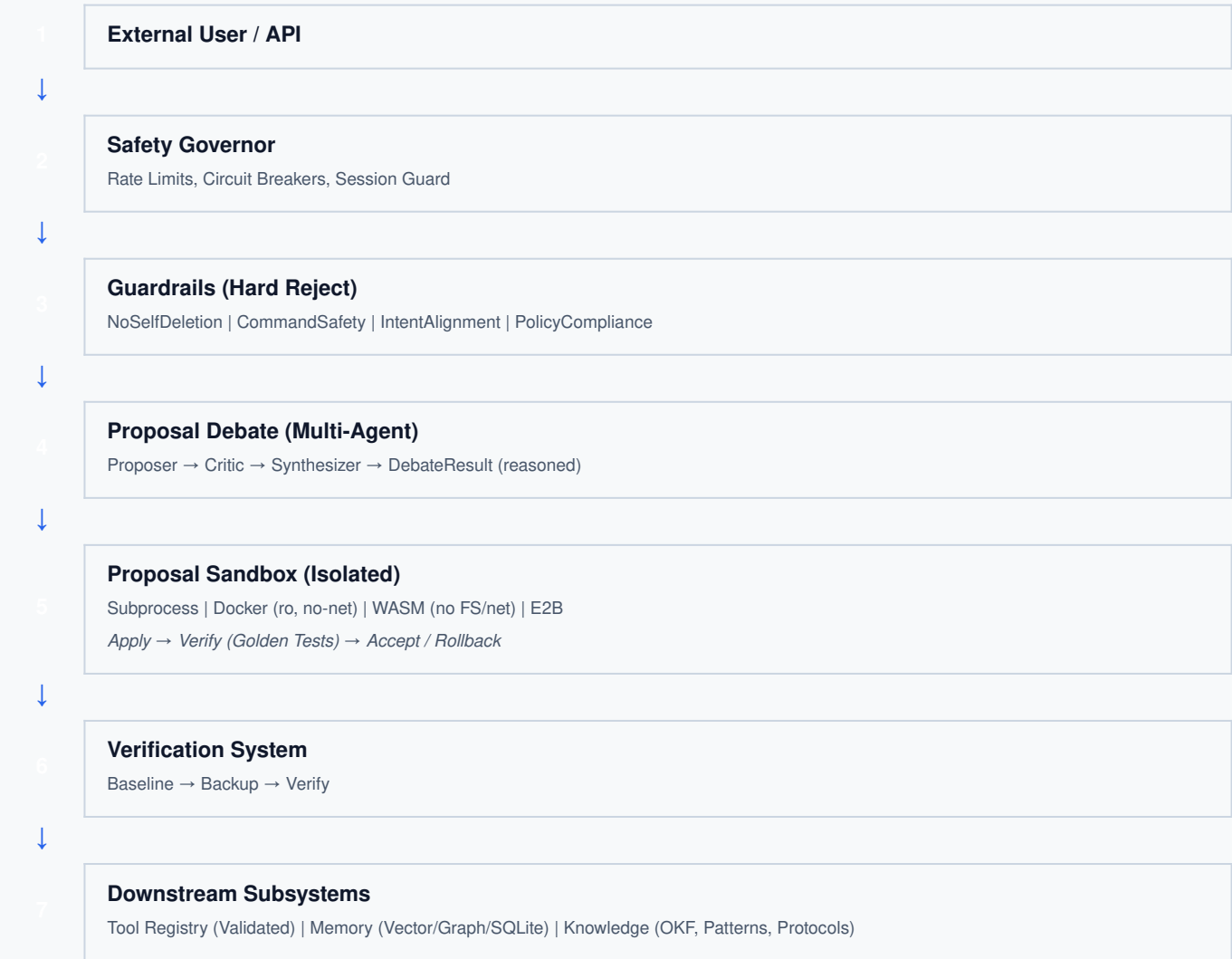
Remaining gaps: The governance documents are a **self-assessment**, external pen test of live build pending, and no user-facing explanation API yet.

Recommendation: Use Odin_Craft today for internal R&D and internal AI-safety reviews under human supervision; before external/regulated deployment, obtain independent legal review and live-build pen test (2–4 weeks).

DIMENSION	BEFORE (31 JUL)	NOW (1 AUG)	ASSESSMENT
Technical Controls	8/10	9/10	Security tooling added (secrets scan, SCA, pen test, tamper-evident log)
Governance Documentation	2/10	8/10	All 8 formal artifacts created under docs/eu_ai_act/
Overall Compliance Readiness	35%	86%	Documentation-complete for voluntary alignment; not a legal certification

Overall Risk Level: **Low** for internal R&D use under human supervision / **Medium-High** for external regulated use until independent legal + security review.

Architecture Overview (Trust Boundaries)



Trust Boundaries: All external calls pass through Safety Governor → Guardrails → Debate → Sandbox → Verification. No direct path from user input to tool execution or memory write.

Findings Matrix (A–F)

A. Autonomy & Control — IMPLEMENTED

ITEM	STATUS	EVIDENCE	SEVERITY IF FAILED
Human approval gates for self-modification	✓	<code>evolver_require_human_approval=True</code> , config.py; SOP docs/eu_ai_act/03	Critical — Uncontrolled self-mod
Circuit breaker / rate limits	✓	Threshold=3, cooldown=86400, rate limits (config.py: 45-51)	High — Runaway loops
Clean stop/pause	✓	<code>.session_active</code> checked by daemons; <code>stop_daemon.ps1</code>	High — Inability to halt
Proposal ↔ Execution separation	✓	ProposalDebate → ProposalSandbox → VerificationSystem	Critical — Unverified changes

B. Safety & Guardrails — STRONG

ITEM	STATUS	EVIDENCE	SEVERITY IF FAILED
Sandbox/isolation for execution	✓	Docker, Subprocess, WASM, E2B; pen test blocks 17 payloads	Critical — Host compromise
Protected files	✓	<code>protected_files.json</code> (10 dirs + 13 files); <code>code_patcher.py</code>	Critical — Agent self-deletion
Value/ethics checks	✓	Guardrails (4 rules); Auditor HARD REJECT	High — Unsafe actions
Rollback capability	✓	<code>ProposalSandbox.rollback_candidate()</code> & <code>code_patcher</code> auto-rollback	High — Irreversible changes

C. Logging & Auditability — GOOD (Improved)

ITEM	STATUS	EVIDENCE	SEVERITY IF FAILED
Actions/decisions logged	✓	<code>AutonomousDecisionLogger</code> ; <code>cycle_log.json</code> (403+ cycles)	Medium — No forensic trail
Reasoning traces	✓	<code>knowledge/okf/agent/reasoning/</code> (30+ entries)	Medium — No root cause
Before/after state	✓	Golden tests, baseline→after verification	Medium — Regressions
Tamper-resistant logs	✓ CLOSED	NEW hash-chain journal (<code>security_journal.jsonl</code>)	High — Audit integrity

D. Learning & Self-Improvement — CONTROLLED

ITEM	STATUS	EVIDENCE	SEVERITY IF FAILED
Self-modification controlled	✓	All gates active	Critical — Unbounded self-mod
Failures recorded	✓	<code>FailureLearner</code> ; <code>causal-graph.json</code>	Medium — Repeated errors
Calibration monitored	✓	Metacognitive calibration in <code>SelfModel</code> & <code>bayesian_reasoner</code>	Medium — Overconfidence
Memory growth bounded	✓	Retention 30 days, max 5000 vectors	Low — Resource exhaustion

E. Tool & External Access — VALIDATED & LIMITED (Improved)

ITEM	STATUS	EVIDENCE	SEVERITY IF FAILED
Tool validation	✓	<code>ToolValidator</code> (syntax→quality→security→tests)	High — Malicious tools
No unrestricted FS/net	✓	Read-only Docker mounts, no-net, empty allowed hosts	Critical — Exfiltration
Secrets not leaked	✓ CLOSED	Automated secrets scan (<code>security_scan_secrets.py</code>) in pre-commit	High — Credentials
Supply-chain risk	✓ CLOSED	SCA scan via <code>pip-audit</code> — 0 vulnerabilities	High — Vulnerable libs

F. Transparency — **PARTIAL (Improved)**

ITEM	STATUS	EVIDENCE	SEVERITY IF FAILED
Agent explains actions	 PARTIAL	Debate results logged; no user-facing explanation API yet	Medium — Black-box
Known limitations		Transparency notice created (docs/eu_ai_act/06)	Low — Misuse
Uncertainty expressed	 PARTIAL	Calibration bias tracked; no standard uncertainty output	Medium — Over-trust

EU AI Act Gap Analysis

First review reported 8 missing formal artifacts. All 8 are now created under docs/eu_ai_act/ (voluntary self-assessment).

#	GAP	EU AI ACT REF	SEVERITY	STATUS	DOCUMENT
1	Formal risk classification	Art.6 + Annex III	High	 CLOSED	01_risk_classification.md
2	Written risk management	Art.9	High	 CLOSED	02_risk_management.md
3	Human oversight procedures	Art.14	Medium	 CLOSED	03_sop_human_oversight.md
4	Transparency notices	Art.50	Medium	 CLOSED	06_transparency_notice.md
5	Data governance	Art.10 + GDPR	Medium	 CLOSED	04_data_governance.md
6	Cybersecurity / Sandboxing	Art.15	Medium	 CLOSED	07_threat_model.md
7	Technical documentation	Art.11 + Annex IV	High	 CLOSED	05_technical_file.md
8	Post-market monitoring	Art.61	High	 CLOSED	08_post_market_plan.md
+	Conformity assessment	Art.43 + Annex VI	—	 CLOSED	09_conformity_assessment.md

Note on Item 5: Current design processes no personal data. If personal data is introduced, severity escalates to High and a DPIA becomes required immediately.

Remediation Roadmap

MILESTONE	STATUS	ESTIMATED EFFORT
All 8 EU AI Act Governance Artifacts & Threat Model	✓ Done	0
Security Tooling (Secrets scan, SCA, Pen test, Hash-chain)	✓ Done	0
Independent legal review of documentation suite	⌚ Pending	1–2 weeks
External live-build penetration test	⌚ Pending	1–2 weeks
Total Estimated Effort for External Readiness		2–4 weeks

Appendix A: Evidence Pack

AREA	KEY FILES
Autonomy & Gates	<code>config.py</code> , <code>safety_governor.py</code>
Sandboxes & Pen Test	<code>sandbox/</code> , <code>scripts/security_pen_test_sandbox.py</code>
Security Tooling	<code>scripts/security_scan_secrets.py</code> , <code>scripts/security_scan_deps.py</code> , <code>scripts/security_log_chain.py</code>
EU AI Act Doc Suite	<code>docs/eu_ai_act/01_risk_classification.md</code> through <code>09_conformity_assessment.md</code>

Generated by Stephane Dube — Independent Review of Odin_Craft codebase.

Methodology: Static code review + config review + log review of 403 cycles, plus verification of new security tooling.

Commit audited: `odin_craft@35c2649`. No dynamic penetration testing performed against live deployment.

This is a technical safety review, not a legal conformity assessment. The `docs/eu_ai_act/` suite is voluntary, self-assessed material.